Risk Plan

PracticeReady Cyber: Scenario-Based Social Engineering and Data Protection Training for GP Reception Staff

Each risk is scored for likelihood (L) and impact (I) from 1 to 5, and **score = L × I**. A score of 15 or above is high, 8–14 is medium and 7 or below is low. Every high risk has a preventive action and a contingency. The register is reviewed at each fortnightly sprint review, and changes are recorded in the sprint diary. The full register is kept in the GitHub repository (`docs/risk-register.md`).

High risks

ID	Risk	L × I	Prevention	Contingency
R1	**Scope creep.** Three training modules (social engineering calls, identity verification, phishing) plus manager features may be more than the time allows.	4 × 4 = 16	Fixed MVP backlog agreed at project initiation. Each module built as a complete vertical slice. Feature freeze before final testing. New ideas logged as further work.	Keep all three modules, including phishing, but reduce the number of scenarios per module and cut lower-priority manager features (such as extra reporting) first.
R2	**Falling behind schedule** due to other modules, coursework clashes or part-time work.	4 × 4 = 16	Two-week sprints with fortnightly supervisor reviews. Gantt chart updated every sprint. Report writing runs alongside development rather than after it.	Use the buffer sprints at the end of the plan. Cut UX polish before core features.
R3	**Security flaw in the application**, such as broken access control, misconfigured database security or leaked keys. Especially damaging for a security product.	3 × 5 = 15	Row-level security denies all direct access by default, and practice isolation is enforced server-side. Automated tests check that one practice cannot read another's data. Secrets kept in server-side environment variables only. Dedicated hardening sprint tested against the OWASP Top 10.	Fix and retest. Record the issue and the fix in the report as evaluation evidence.
R4	**Data loss** from laptop failure, accidental deletion or cloud sync corrupting the repository.	3 × 5 = 15	Push to GitHub at least daily. Repository kept outside OneDrive. Report drafts stored in the cloud. *Already mitigated.*	Re-clone from GitHub, losing at most a day's work.

Medium risks

ID	Risk	Score	Prevention and contingency
R7	Inaccurate scenarios teach the wrong procedure	12	Base scenarios on published guidance (NCSC, ICO, NHS England, BMA confidentiality guidance). Manager approval required before modules go live. Weak scenarios are returned to draft and revised.
R8	Weak evaluation without real users	12	Test plan with automated verification and scenario walkthroughs against the aims. Agree early with the supervisor whether peer testing is acceptable. If not, use an expert-style heuristic review and state the limitation.

R17	No ethics approval for user testing with peers or GP staff	12	Ask the supervisor whether approval is needed and apply early. No testing with participants until it is granted. If it isn't granted in time, evaluate with automated tests and an expert-style heuristic review only.
R10	Academic integrity around generative AI use	10	Log and declare all AI use. Be able to explain every part of the submitted work at the viva.
R16	Demo fails at the showcase, video or viva	10	Tag a stable demo build before the deadline. Record the video in advance. Keep a local fallback build with seeded demo accounts.
R19	Developer accounts compromised (GitHub, Supabase, Vercel)	10	2FA on every account, a password manager and GitHub secret scanning. If it happens, revoke sessions, rotate all keys and restore from the repository.
R18	No access to GP practices or domain experts to check procedures	9	Base procedures on published guidance (BMA, ICO, NHS England) and contact a practice manager informally where possible. Discuss the limitation in the evaluation.
R5	Framework issues with TanStack Start	9	Lock dependency versions. Keep business logic in plain TypeScript so it can move to another framework if needed.
R6	Supabase or Vercel outage, free-tier pause or hosting limits	9	Database migrations kept in the repository so it can be rebuilt. Local build and mock backend for development and demos.
R13	Vulnerable npm dependency	9	`npm audit` and Dependabot alerts. Keep dependencies to a minimum. Patch or replace affected packages.
R14	Accessibility barriers stop some staff using the training	9	Accessible shadcn/Radix components. Keyboard and screen-reader testing against WCAG 2.2 AA. Fix high-impact issues first.
R11	Illness or personal circumstances	8	Buffer sprints in the plan. Tell the supervisor early. Apply for extenuating circumstances if needed.

Low risks

ID	Risk	Score	Prevention and contingency
R15	Invitation emails not delivered	6	Managers can copy the invite link from the app and share it manually.
R21	Trainee results used to judge or monitor staff	6	Collect minimal trainee data, make clear what managers can see, and frame results as support rather than performance management. Covered in the LSEP section.
R9	Real patient data enters the system	5	Only fictional data is used, with no real users during development. If it happens, delete the data immediately and inform the supervisor.
R20	Dev-mode mock logins reach a production build	5	Dev mode only runs on localhost in development builds. A test or build check will prove that production can't enable it.
R12	Supervisor unavailable for a sprint review	4	Send an email update and record self-review notes in the sprint diary.
R22	Phishing module examples misused	3	Phishing examples stay inside the app. No real simulated phishing emails are sent, and only clearly fake domains are used.